Contents

1 Disaster Recovery Plan **1**
1.1 1. Purpose And Scope . . . 1
1.2 2. Recovery Objectives . . . 1
1.3 3. Offsite Backup Location And Protection . . . 1
1.4 4. Roles And Responsibilities . . . 2
1.5 5. Activation And Communications . . . 2
1.6 6. Recovery Procedures . . . 2
1.6.1 6.1 System Failure: Application, Infrastructure, Or Dependency Outage . . . 2
1.6.2 6.2 Data Loss, Corruption, Or Failed Migration . . . 3
1.6.3 6.3 Cyber Incident, Unauthorized Access, Or Ransomware . . . 3
1.6.4 6.4 Region Or Provider Outage . . . 3
1.7 7. Recovery Acceptance Checklist . . . 3
1.8 8. Testing And Evidence . . . 3
1.9 9. Post-Incident Review . . . 4
1.10 10. Version And Approval Record . . . 4

1 Disaster Recovery Plan

System: Vitora HMIS **Owner:** Nexora Consulting Ltd Operations Lead **Approval required from:** Security Lead and designated facility representative **Review frequency:** Annual and after every material incident or recovery exercise

1.1 1. Purpose And Scope

This plan restores safe clinical-system operation after a production service failure, data corruption, security incident, backup failure, or cloud-region disruption. It covers the web application, Django API, PostgreSQL data, Azure Blob backup copies, application configuration, and facility-hub recovery procedures.

This plan does not replace a facility's clinical downtime procedure. Facilities must maintain an approved process for paper or temporary clinical documentation during downtime and reconcile those records after recovery.

1.2 2. Recovery Objectives

Objective	Target	Measurement
Recovery Time Objective (RTO)	24 hours	Time from declared recovery incident to restored and verified service
Recovery Point Objective (RPO)	24 hours	Maximum accepted data loss window based on daily backup cadence
Backup frequency	Daily	Scheduled production database backup at 02:00 UTC / 05:00 EAT
Restore validation	Monthly	Isolated restore drill of the latest backup

The RTO and RPO are policy targets, not measured guarantees. Actual recovery performance must be recorded in restore drills and incidents.

1.3 3. Offsite Backup Location And Protection

Production PostgreSQL backup archives, their SHA-256 checksum files, and necessary restore metadata are stored offsite in the private Azure Blob Storage `db-backups` container. This storage is separate from the production application runtime and is not publicly accessible. The storage account name, Azure region, retention configuration, access-control assignments, and approved recovery credentials are maintained in the controlled operations asset and secret registers rather than this document.

Facility-hub encrypted backup bundles are stored only at the approved offsite destination configured for that hub. The destination must be geographically and contractually approved for the facility's data-residency obligations; its physical or provider location and replication location must be recorded in the facility's controlled backup register before backup uploads are enabled.

Operations must verify the following at least monthly as part of the restore drill:

- The latest backup and matching checksum are present at the offsite location.
- The backup can be retrieved by authorized recovery personnel.
- The backup can be decrypted and restored in an isolated environment.
- Public access remains disabled and backup access follows least privilege.

1.4 4. Roles And Responsibilities

Role	Responsibilities
Incident Commander	Declares incident severity; activates this plan; authorizes service susp
Operations Lead	Leads technical recovery; coordinates infrastructure, deployment, DN
Security Lead	Leads cyber-incident containment; preserves evidence; assesses compr
Application Lead	Diagnoses application and migration faults; prepares or approves rolll
Clinical/Facility Liaison	Activates the facility downtime process; communicates status and wo
Data Protection Officer / Compliance Lead	Assesses legal, contractual, and regulatory notification obligations; ap
Communications Lead or Incident Commander delegate	Sends approved internal, facility, supplier, and customer status updat

Named contacts, deputies, supplier escalation contacts, and after-hours numbers must be maintained in the controlled operations contact register and must not be embedded in source control.

1.5 5. Activation And Communications

Activate this plan when any of the following occurs:

- Production API or web application is unavailable beyond the operational threshold.
- Database corruption, accidental destructive change, or failed migration is suspected.
- Backup creation, upload, checksum, or restore verification fails.
- Ransomware, credential compromise, unauthorized data access, or audit-log anomaly is suspected.
- A cloud-provider or regional incident materially affects service availability.

The Incident Commander records the start time, affected services, decision owner, containment actions, selected recovery point, restoration result, and stakeholder notifications. Communications must not contain patient identifiers unless an approved secure channel and lawful purpose apply.

\newpage

1.6 6. Recovery Procedures

1.6.1 6.1 System Failure: Application, Infrastructure, Or Dependency Outage

1. Incident Commander declares the incident, opens the incident log, identifies affected facilities and services, and asks the Clinical/Facility Liaison to activate the applicable downtime procedure.
2. Operations Lead confirms scope through monitoring, the service health endpoint, provider status, DNS checks, and dependency checks for the application, database, storage, and identity services.
3. Application Lead determines whether a recent release, migration, configuration change, capacity issue, or external dependency is the likely cause.
4. For a release-related failure, Operations Lead rolls back to the last known-good revision. For runtime or infrastructure loss, redeploy the approved application revision and required configuration into the approved recovery environment.
5. Restore database or object-storage data only when a dependency failure cannot be corrected without restoration; otherwise preserve the current data state.
6. Validate HTTPS, authentication, tenant isolation, critical API health, audit logging, background jobs, and essential clinical workflows before inviting facility users back to the service.
7. Incident Commander approves service restoration, Communications Lead sends the recovery update, and the team records the elapsed recovery time against the 24-hour RTO.

1.6.2 6.2 Data Loss, Corruption, Or Failed Migration

1. Declare the incident and restrict write traffic where possible.
2. Preserve the current database state and relevant logs before destructive recovery actions.
3. Identify the latest verified backup that predates the failure.
4. Verify the SHA-256 checksum and decrypt the backup only in the controlled recovery environment.
5. Restore first into an isolated PostgreSQL environment.
6. Validate migrations, tenant counts, recent synthetic/known records, audit-log availability, and application health.
7. Obtain Incident Commander approval before replacing production data.
8. Restore production, restart services, monitor errors, and reconcile any documented downtime records.

1.6.3 6.3 Cyber Incident, Unauthorized Access, Or Ransomware

1. Isolate affected services and revoke exposed credentials, tokens, and sessions.
2. Preserve logs, audit trails, infrastructure events, and a forensic copy of affected data where lawful and safe.
3. Determine the earliest trusted recovery point.
4. Deploy a clean environment with rotated application secrets, encryption keys where required, service credentials, and administrator credentials.
5. Restore only verified data into an isolated environment before production cutover.
6. Review accounts, MFA status, role assignments, third-party integrations, and audit integrity.
7. Coordinate breach assessment and notifications through the Data Protection Officer and legal/compliance process.

1.6.4 6.4 Region Or Provider Outage

1. Confirm provider scope using Azure and DNS/provider status evidence.
2. Communicate the expected outage and facility downtime procedure.
3. Restore service in the approved alternate environment only when current infrastructure, backup location, residency, and supplier arrangements have been approved.
4. Validate data consistency and reconcile offline/downtime records before resuming normal operations.

\newpage

1.7 7. Recovery Acceptance Checklist

Recovery is complete only when the following are recorded:

- ☐ Backup checksum and decryption/restore verification passed.
- ☐ Database migrations and health checks passed.
- ☐ HTTPS, authentication, and protected API checks passed.
- ☐ Tenant/facility access smoke checks passed using synthetic records where available.
- ☐ Audit logging is active and audit records are queryable.
- ☐ Media/object storage access is validated.
- ☐ Required external integrations are tested only after clinical and security approval.
- ☐ Downtime records and pending offline writes are reconciled.
- ☐ Stakeholders receive recovery completion communication.
- ☐ Post-incident review, corrective actions, and evidence are recorded.

1.8 8. Testing And Evidence

The repository contains a daily production backup workflow and a monthly isolated restore drill. The drill retrieves the latest offsite backup, verifies the checksum, restores it into isolated PostgreSQL, and checks the restored migration table. Evidence required for DHA/facility review includes the workflow run, backup timestamp, offsite location verification, restore duration, checksum result, achieved recovery point, exceptions, and corrective actions.

Facility-hub recovery uses encrypted backup bundles and the dedicated hub restore runbook: `docs/hub-backup-recovery.md`.

\newpage

1.9 9. Post-Incident Review

Within ten business days of a material incident or recovery exercise, the Incident Commander must convene a review with the Operations Lead, Security Lead, Application Lead, Clinical/Facility Liaison, and Data Protection Officer/Compliance Lead as applicable. The review record must include:

- Timeline, incident classification, affected systems, and decisions made.
- Measured recovery time and recovery point, assessed against the 24-hour RTO and 24-hour RPO.
- Confirmed or suspected impact on confidentiality, integrity, availability, and clinical operations.
- Reconciliation outcome for downtime, offline, and delayed records.
- Root cause, corrective actions, action owners, deadlines, and verification status.
- Whether this plan, the backup policy, supplier contacts, or the offsite backup register require revision.

\newpage

1.10 10. Version And Approval Record

Item	Record
Current version	1.1
Last reviewed	15 October 2026
Next scheduled review	15 October 2027
Additional review triggers	Material incident, failed restore, material infrastructure change, or change to backup location/provi

Approval role	Name	Signature or approved electronic equivalent	Date
Operations Lead			
Security Lead			
Designated facility representative			

The controlled approved copy must contain the completed approval record. The Operations Lead retains it with associated test and incident evidence in the controlled operations records repository.